

PRODUCT THINKING DECK

Zepto Consent Redesign

ADYASHA MAHANTA

July 2026

One consent event covers everything, even your health data



The core problem

Today: Zepto collects ordinary data (address, order history) and sensitive data (health, medical, biometric) under one blanket “accept everything” consent at signup.

DPDP requires: specific consent per purpose, with a higher bar for sensitive data. Zepto has neither.

Focus: how Zepto handles sensitive personal data at consent and withdrawal, under DPDP Section 6.

WHY IT MATTERS

● User trust

Zepto has faced public questions over inferring menstrual/mood signals from search behaviour without clear disclosure.

● Legal risk

Breach of Section 6 , 8 and 11 can draw penalties up to ₹150–200 Cr; sensitive-data mishandling invites deeper regulatory scrutiny.

● Structural gap

Today, withdrawing consent means leaving the platform entirely — there is no partial, purpose-level control.

ASSUMPTIONS

- Zepto sells medicine as a live feature. Current consent is a one-time blanket accept at signup.
- All metrics and dashboard figures are mock data.

The person whose data is actually at stake



Priya, 29

Bengaluru · works in tech · lives alone

Orders groceries weekly and, occasionally prescription medicines for a chronic condition through the same Zepto account and the same consent screen.

Data at stake

Health info, precise location, order history, and payment details — all flowing through one blanket consent.

Pain points today

She has no idea her medicine orders are treated the same as her groceries. She can't share her location without also sharing her health data. Her only “off switch” is deleting her account.

Why it matters for her

Misused health data, profiling, or worse is a far bigger risk to her than a leaked grocery preference.

Where today's flow falls short of DPDP Section 6

Current step	What Section 6 requires	The gap
Single “I agree” checkbox at signup covers all data	Consent must be free, specific, and limited to what's necessary per purpose	No separation of purposes — sensitive and ordinary data bundled together
Health & medical data collected via the same flow as groceries	Sensitive categories warrant a distinct, explicit consent step	No elevated bar for health, medical, or biometric data
Withdrawing consent = leaving the platform entirely	Withdrawal must be as easy as giving consent (Sec. 6(4))	Withdrawal is all-or-nothing, not per-purpose

Tier the consent by data sensitivity



Tiered consent at signup

Standard data (address, order history) uses today's lightweight flow. A separate, explicit consent step triggered contextually when a health/medicine feature is first used covers sensitive personal data.



Granular Consent Center

Replace the binary “withdraw = leave” model with per-purpose toggles: location, marketing, sensitive health data, each independently revocable, in-app, instantly.



Privacy-by-default toggle state

Marketing, analytics, and third-party sharing ship OFF by default for all users, not just sensitive-data users; users opt in at Consent Center

Why this over a full privacy-dashboard rebuild: it fixes the highest-risk data (health) fast, with far less engineering work than a full rebuild and closes sharpest compliance gap first.

How we'd know this is actually working

NORTH STAR METRIC

% of users with valid
and up-to-date consent

Tracked separately for regular data and
sensitive data

*Why this metric: it shows real compliance. A
user who skips the health-data screen doesn't
count as covered.*

SUPPORTING METRICS

- ✔ Signup consent completion rate
- ✔ Health-data consent opt-in rate
- ✔ Monthly engagement rate

GUARDRAIL METRICS

- ⚠ Signup drop-off rate i.e. compliance shouldn't hurt conversion
- ⚠ Support tickets tagged “consent or privacy confusion”

SUCCESS CRITERIA

- 90%+ finish signup without dropping off
- Health-data consent step adds < 3% extra drop-off
- 100% of withdrawals handled in-app, no support ticket needed
- Consent Center used by 12%+ of monthly users in Q1

North Star drops 15% in week 3 — no major release shipped

Technical / backend

A tagging bug wrongly marks users as unconsented, or an expiry job fires too early.

Funnel

More signups drop off at the health-consent step, maybe an OS or UI change.

Behavioural / trust

More users are withdrawing consent, tied to a news story or complaints.

Segment-specific

The drop only shows up on one platform or in one region, not everywhere.

DATA I'D PULL

- Funnel: signup → consent → completion
- Withdrawal volume and stated reasons over time
- New vs. existing user cohorts
- Platform and OS breakdown
- Release timeline vs. news or support spikes

ROOT-CAUSE APPROACH

Split the drop in two: are fewer new users giving consent, or are more existing users losing it? That split points to the right cause above.

NEXT STEPS

- Hotfix it, if it's a bug
- Roll back the release, if funnel-related
- Send a trust update, if news-driven
- Otherwise, wait one more week to confirm the trend

Monitoring consent health (mock data)

MAIN KPI

78 %

valid, current consent

▼ 4 pts vs. last month

SUPPORTING METRICS

92%

Signup completion

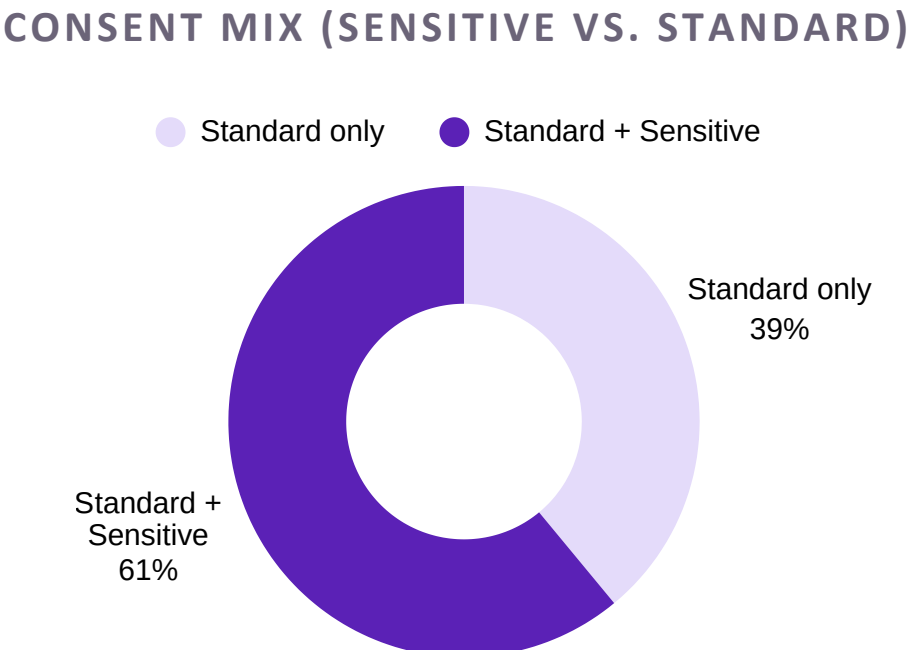
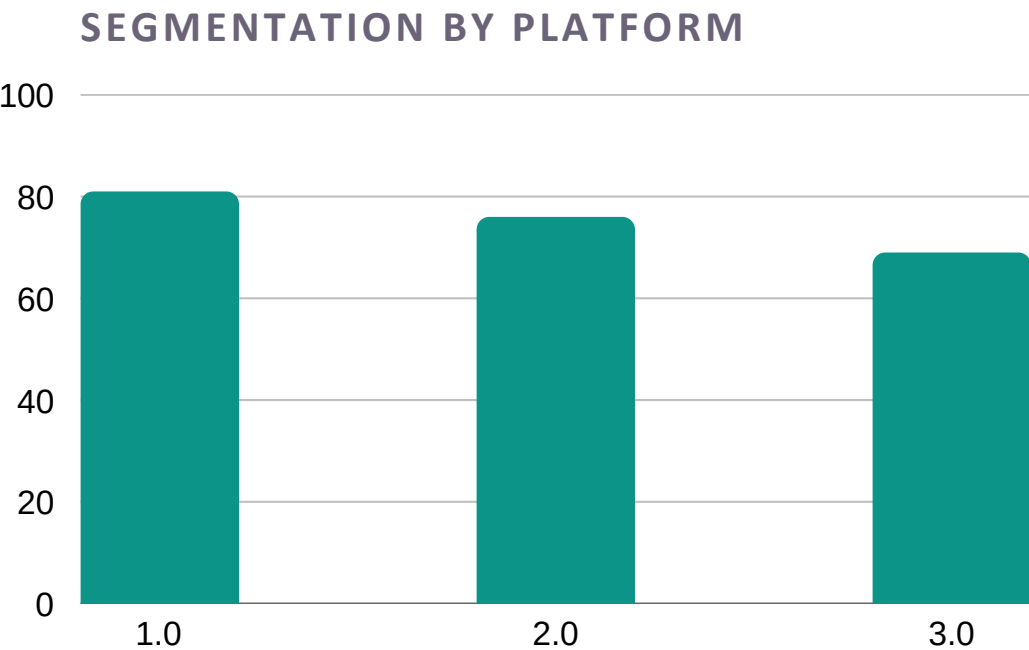
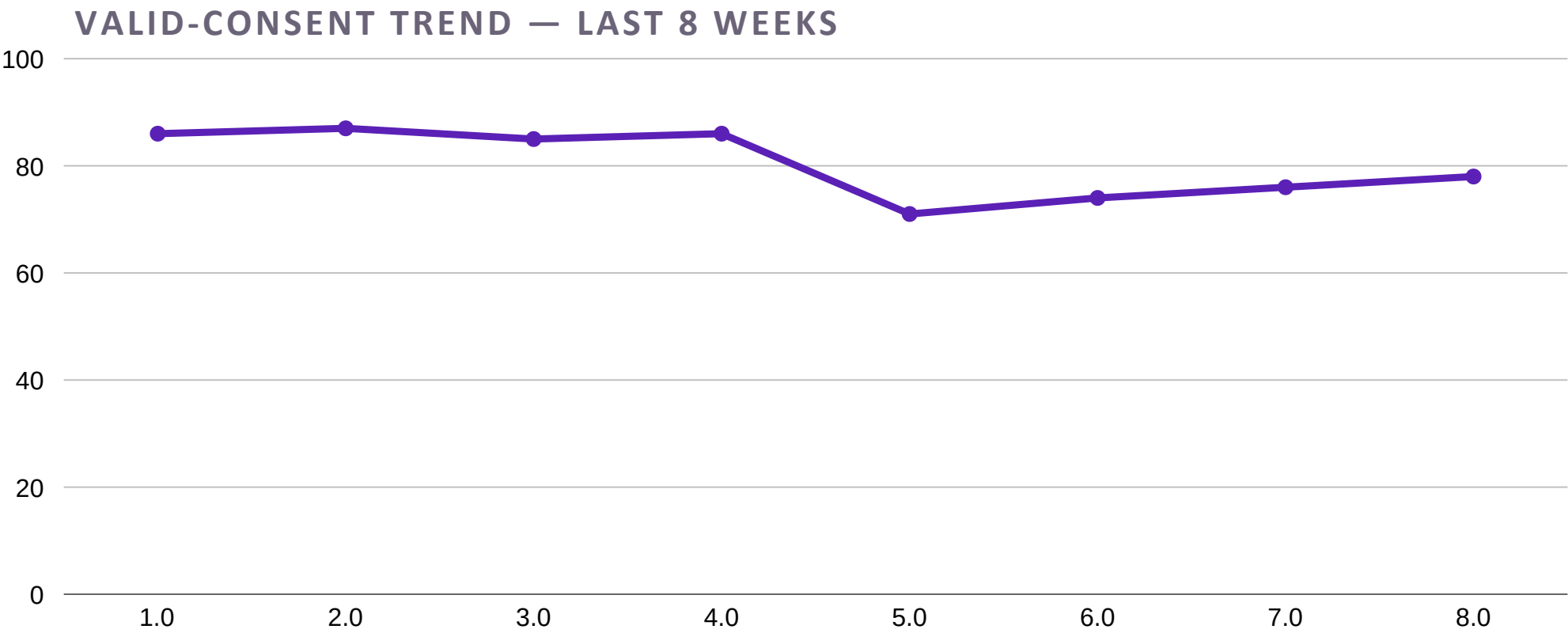
61%

Sensitive-consent opt-in

2.1%

Withdrawal rate

Zepto · DPDP Section 6 Consent Redesign



READING THE DASHBOARD

The Week-5 dip lines up with the diagnostic scenario on the previous slide exactly why the trend line and platform split live on the same screen as the KPI.

Web trails iOS/Android are worth a closer look at the browser consent flow.

Ship the compliance-critical part to everyone — test the rest

01

Soft launch

Tiered consent flow ships to 10% of new signups, feature-flagged, with close funnel monitoring.

02

Existing-user notice

Staggered re-consent prompts to the existing base, per Section 5(2)'s notice requirement for prior consent.

03

Full rollout

100% of new + existing users on the tiered flow; Consent Center goes generally available.



What we CAN A/B test

- Copy and order of the consent steps
- Whether asking about location before or after health data changes opt-in
- Visual design of the Consent Center toggles



What we CANNOT A/B test

- Whether to offer tiered, sensitive-data consent at all
- It's a legal requirement, not a growth test

Compliance and trust, deliberately chosen over frictionless growth

Trade-off accepted: we're choosing real compliance and long-term trust over short-term, frictionless growth.



Engineering complexity

A single yes/no flag becomes a full consent ledger, what was agreed, when, and which version. Real backend work.



Business impact

Extra friction at signup or first medicine order may cost some conversion in the health-adjacent vertical.



User impact

Some users will find the added steps annoying in the short term, even if the long-term trust payoff is real.



Edge cases

Users who decline health consent must still be able to order groceries — partial, not full, lockout. Minors: Zepto's current policy is inconsistent and needs a real fix, not just a disclaimer.

Thank You